

PrimeHealth Clinic & Diagnostic

Information Security Risk Treatment Plan

Document Version History

Date	Version	Updated By	Details of Change	Approved By
21/10/2024	1.0	Whole Team	Basic Draft of document	Executive Team
22/10/2024	1.0	Whole Team	Draft in progress	Executive Team
24/10/2024	1.0	Whole Team	Document Complete	Executive Team
27/10/2024	1.0	Whole Team Aaron (CEO)	Approval	Executive Team

Table of Content

Purpose.....	2
Scope	2
Definitions	3
Principles.....	3
Roles and Responsibilities	3
Risk Appetite	4
Risk Identification	5
Risk Assessment	5
Risk Register	6
Risk Reporting.....	6
Risk Review	6
Risk Treatment	6
Steps for Risk Treatment	7
Risk Acceptance.....	7
Risk Mitigation	7
Control Identification	7
Cost Estimation of Identified Controls.....	8
Policy Compliance.....	9

Purpose

The purpose of this policy is to establish a structured approach to identifying, assessing, managing, and treating information security risks at PrimeHealth Clinic & Diagnostics. It aims to protect the confidentiality, integrity, and availability of information assets by applying appropriate risk treatment measures in line with ISO 27001:2022 standards. This policy also ensures alignment with the organization's risk appetite and guides the process for risk evaluation, mitigation, and reporting.

Scope

This document applies to PrimeHealth's business processes and information assets that impact the organization's information security.

Definitions

- **Information Security Risk:** The potential for loss, theft, or damage to information assets resulting from vulnerabilities being exploited by internal or external threats.
- **Residual Risk:** The level of risk remaining after the application of security controls.
- **Risk Appetite:** The level of risk that an organization is willing to accept to achieve its objectives.
- **Risk Treatment:** The process of selecting and implementing measures to mitigate, transfer, avoid, or accept identified risks.
- **Statement of Applicability (SoA):** A document listing the controls chosen to mitigate identified risks, along with justifications for their inclusion or exclusion.

Principles

The key principles of this policy are:

1. **Proactive Risk Management:** Risks are identified, assessed, and treated before they can impact the business.
2. **Compliance:** The policy ensures compliance with relevant laws, regulations, and **ISO 27001:2022** standards.
3. **Continuous Improvement:** Risk treatment strategies are reviewed and enhanced over time based on emerging threats and feedback.
4. **Alignment with Business Goals:** Risk treatment efforts are aligned with PrimeHealth's strategic goals and operational priorities.

Roles and Responsibilities

Chief Security Officer (CSO):

- Oversees the entire risk treatment process.
- Ensures that risk treatment measures are aligned with ISO 27001 requirements.
- Approves the implementation of selected controls and the acceptance of residual risks.
- Provides regular updates to top management regarding risk treatment status and effectiveness.
- Coordinates resources necessary for the implementation of controls.

Risk Owners

- Assigned to each identified risk.
- Responsible for ensuring that identified risks in their respective departments or systems are treated.
- Monitor the implementation of controls and their effectiveness.
- Report progress and residual risk status to the **Information Security Committee (ISC)**.

Information Security Committee (ISC):

- Reviews and approves the selected risk treatment measures and controls.
- Ensures that all risks rated above **Minor** are treated in accordance with the risk appetite.
- Monitors overall risk management processes and ensures continuous compliance with **ISO 27001** standards.

IT Department:

- Implements the technical controls identified in the risk treatment plan (e.g., access controls, encryption).
- Monitors systems and applications to ensure compliance with security controls.
- Reports any security incidents or breaches to the **CSO** and **ISC**.

Employees:

- Comply with security policies, procedures, and controls, particularly those relating to data protection, access controls, and incident reporting.
- Report any potential risks or security incidents to the IT or security teams.
- Participate in regular security awareness training sessions.

Third-Party Vendors and Contractors:

- Comply with the security requirements specified in contracts and the **Vendor Risk Assessment**.
- Ensure the security of any data or systems they handle on behalf of PrimeHealth.
- Provide compliance evidence or reports demonstrating adherence to PrimeHealth's risk treatment strategies

Risk Appetite

PrimeHealth deems any risks above a 'minor' level unacceptable for the company. This means:

- Accepted Risks: Risks rated as Minor or lower can be accepted without further treatment.
- Treated Risks: All risks rated above Minor (i.e., Moderate, Major, or Extreme) must be treated using appropriate risk mitigation strategies.
- High Priority Risks: Risks rated as Major or Extreme must be escalated and treated immediately due to their significant impact on the organization.

PrimeHealth maintains a low-risk appetite for areas concerning patient care, diagnostics, and regulatory compliance. Risks that could lead to breaches of patient data, disruption of diagnostic services, or non-compliance with regulations must be minimized and treated aggressively.

Our Risk Appetite is Minor, the threats with risk rating Extreme, Major and Medium would be treated with controls, these risks are unacceptable risks to the organization. Threats with risk rating minor or negligible will not be implemented with controls, the company accepts the risks.

The risks and their response would be found in the Risk Response in **04. [ISO27K1_8.2]**

Business Processes, Information Assets & Risks Register

Risk Identification

The risk identification process aims to detect potential risks that could compromise the confidentiality, integrity, or availability of PrimeHealth's information assets. Risks are identified through:

- Regular assessments of all business processes.
- Threat intelligence feeds and monitors emerging risks.
- Employee feedback on vulnerabilities within the information systems.
- All identified risks are documented in the Risk Register for further evaluation.

Risk Assessment

PrimeHealth assesses identified risks based on their likelihood and potential impact on operations. Each risk is classified according to its:

Severity: The potential consequences if the risk materializes.

Likelihood: The probability of the risk occurring.

Impact on business functions: How severely it could affect patient care, diagnostics, or other critical business areas.

This assessment allows for the prioritization of risks and the selection of appropriate treatment measures.

Risk Assessment Process

PrimeHealth assesses risks by evaluating their **likelihood** and **impact** on the business. A customized risk matrix, aligned with the organization's Minor Risk Appetite, is used for risk evaluation.

Key Interpretation:

- **Minor and Below:** Accepted and do not require additional treatment.
- **Above Minor (Moderate, Major, and Extreme):** Must be treated.
- **Major/Extreme:** Escalated for immediate treatment due to high potential impact.

Risk Register

All identified risks, along with their assessments, are recorded in PrimeHealth's Risk Register. This central document tracks:

- Risk descriptions.
- Associated business functions.
- Assigned risk owners.
- Risk treatment measures.
- Residual risk after treatment.

The Risk Register is reviewed regularly and updated with new risks as they are identified. The identified risks can be found in the TRA and Risk response worksheet in **[ISO27K1_8.2] Business Processes, Information Assets & Risks, Register,** file. This file will be updated on regular basis based on new risk identification or any other new information to be updated.

Risk Reporting

Risk reporting ensures that management is informed of current risks and their treatment status. PrimeHealth will generate quarterly risk reports, which will be reviewed by senior management and relevant stakeholders. These reports will include:

- Risk status updates.
- Progress on treatment measures.
- Newly identified risks. Urgent risks, particularly those affecting patient care or regulatory compliance, will be reported immediately.

Risk Review

Risks and controls are reviewed on an ongoing basis to ensure the effectiveness of the risk treatment measures. Regular risk review meetings are conducted by the Information Security Committee to:

- Assess whether existing controls remain effective.
- Identify any changes in the threat landscape.
- Adjust risk treatment strategies if necessary.

Risk Treatment

Risk treatment involves selecting the most appropriate action to manage a risk. Options include:

1. Risk Avoidance: Avoiding activities that introduce significant risks, especially those outside PrimeHealth's risk appetite.
2. Risk Reduction: Implementing controls to reduce the likelihood or impact of identified risks. This may include encryption, access control, and regular system updates.
3. Risk Transfer: Transferring the risk to a third party, such as by outsourcing services or obtaining insurance.
4. Risk Acceptance: Accepting residual risks when they are deemed manageable and within PrimeHealth's risk appetite. This requires approval from the CSO and risk owners.

Steps for Risk Treatment

1. Select the risk treatment approach within in the ISMS framework.
2. Provide a risk rating to each of the risks given in TRA under (Business Processes, Information Assets & Risks Register.xlsx, As a result of a threat capitalising on a vulnerability associated with an information asset, appropriate controls are found to counteract (mitigate) these risks. The Scenario Analysis, which is used to identify threat vectors, likelihoods, and vulnerabilities, can help lead the selection of appropriate policies. These restrictions are then documented in the TRA.
3. Identify the risk rating for risk treatment: For every threat in the TRA, provide a risk rating. If the risk rating is extreme, major or medium, risks would be treated with controls and minor or negligible risk rated threats will be accepted by the organisation.

Risk Acceptance

Risks that are deemed to fall within PrimeHealth's risk appetite may be accepted, provided there is formal approval by the risk owner and the CSO. Accepted risks will still be monitored, and controls may be implemented if the situation changes. Risks with risk rating minor or negligible would-be acceptable risks for the organisation

Risk Mitigation

PrimeHealth's risk mitigation strategy involves reducing risks through the application of technical, procedural, and physical controls. These measures are designed to lower the risk's likelihood or impact and ensure that critical systems and data remain secure.

Controls will be implemented for risks with Risk rating as Extreme, major or medium.

Control Identification

For all risks rated above **Minor**, controls are selected based on the risk assessment. Controls are aligned with **ISO 27001:2022 Annex A** and are reviewed for its effectiveness and cost-benefit ratio before implementation.

The listed controls for risk are mentioned under the Statement of Applicability Sheet [ISO27K1_6.1.3_B] Statement of Applicability.xlsx, this sheet will be under continuous review for implementation of controls and improvisation.

Cost Estimation of Identified Controls

Cost estimation for the implementation of identified controls is performed based on the following factors:

- **Technology Costs:** Hardware, software, and licenses required to mitigate risks.
- **Personnel and Training Costs:** Costs associated with employee training and awareness programs.
- **Monitoring and Maintenance Costs:** Ongoing costs for system updates, audits, and monitoring tools.

The costs are documented in the Controls sheet in the [ISO27K1_8.2] Business Processes, Information Assets & Risks, register workbook and compared against the potential benefits of risk mitigation.

Identifying Controls for Threats

PrimeHealth identifies controls through a structured risk assessment process, referencing **ISO 27001:2022 Annex A** for selecting relevant security measures. Controls are tailored to mitigate specific risks, such as using **access controls**, **encryption**, and **incident response** mechanisms. The controls are chosen based on their effectiveness in reducing the likelihood and impact of identified threats, with consideration for compliance requirements and industry best practices.

Estimating the Cost of Controls

Cost estimation considers several factors, including **technology acquisition** (hardware/software), **training** for employees, **integration costs**, and **ongoing maintenance**. A **cost-benefit analysis** is conducted to ensure that the chosen controls provide optimal risk reduction while remaining within budget. All costs are documented in the **Risk Register** and reviewed for feasibility and financial impact.

Policy Compliance

All employees, contractors, and third-party service providers are expected to comply with this Information Security Risk Treatment Policy. Non-compliance will result in appropriate disciplinary action and may include:

- Retraining.
- Escalation to senior management.
- Suspension of system access.
- PrimeHealth will conduct regular audits to ensure adherence to this policy and ISO 27001 standards.
- Monitoring and Continuous Improvement

PrimeHealth is committed to continuously improving its risk management processes. This policy will be reviewed annually, or when significant changes in the risk environment occur, to ensure its continued relevance and effectiveness

Supporting reference and evidence documents

- ISMS Scope
- [ISO027K1_6.1.2] Information Security Risk Assessment
- [ISO27K1_8.2] Business Processes, Information Assets & Risks, Register
- [ISO27K1_6.1.3_B] Statement of Applicability
- [ISO27K1_6.2] Information Security Objectives & Plans